

1. OVERVIEW

An overview of Requirement 8 (“Identify Access”), and its sub-requirements.



REQ. 8: IDENTIFY ACCESS

REQ. 8: IDENTIFY ACCESS OVERVIEW

Requirement 8 (Identify Users and Authenticate Access to System Components) is about identification.

- Making sure that whoever authenticates for operations is who they say they are;

This requirement focuses mostly on:

- Having strong authentication practices (e.g., MFA) for all practices related to the CDE;
- Managing user accounts - and their permissions - in a very strict manner (such as administrators, for example);
- Accounts being unique (so we can track actions to a user), and not having public or shared accounts;
- Ensuring the processes for this are well-defined;

REQ. 8: IDENTIFY ACCESS

OVERVIEW

The sub-requirements for this requirement include:

- 8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.
- 8.2 User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle.
- 8.3 Strong authentication for users and administrators is established and managed.
- 8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.
- 8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse.
- 8.6 Use of application and system accounts and associated authentication factors is strictly managed.





REQ. 8: IDENTIFY ACCESS

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood

- As usual, all processes and policies related to authentication/identification must be documented and enforced, as well as the definitions of roles and responsibilities for personnel;

This is usually tested through:

- Examining the documentation to gauge whether it represents the practices, and whether it's enforced. The same for definitions of roles and responsibilities;
- Interviewing personnel for the same purpose;

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

8.2 User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle

- This is about ensuring non-repudiation of actions. Each user must have a unique account with a unique ID, sessions expire after 15 minutes, group accounts cannot be used save for exceptions, 90-day inactive accounts must be immediately removed. Account changes must be formal;
- Third-party accounts are temporary and heavily monitored;

This is usually tested through:

- Examining account and login records to verify account creation, deletion, session expirations;
- Interviewing personnel on account mgmt. procedures;





REQ. 8: IDENTIFY ACCESS

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

8.3 Strong authentication for users and administrators is established and managed

- Actions must have an additional authentication factor besides password (know/have/are), credentials must be encrypted, users must receive guidance;
- Passwords cannot be reused, and must have 12 characters, numbers + letters, as well as being periodically updated;
- Lockouts on 10 failed attempts for 30 minutes;
- Physical auth. devices cannot be shared across users;

This is usually tested through:

- Verifying documentation on password requirements;
- Verifying records of password changes + lockout processes;
- Interviewing personnel on authentication practices;

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE

- This sub-requirement mandates that MFA is required for more “sensitive” operations. These include:
 - Administrators remotely performing actions;
 - All personnel dealing with card data, in general;
 - All actions from outside our network/from third parties;
- Technically, one includes the others, but it’s for emphasis;

This is usually tested through:

- Examining networks and interfaces for MFA requirements (remote admins + external networks + 3rd parties);
- Examining login records of various users in various systems, to verify MFA is required across the CDE;





REQ. 8: IDENTIFY ACCESS

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse

- This sub-requirement is basically around enforcing that MFA cannot be abused. Replay attacks cannot be performed, MFA cannot be bypassed, there must be at least two different types of authentication factors, and success on all factors must occur before access is granted;

This is usually tested through:

- Examining vendor system documentation, system configurations and personnel login records;
- Interviewing personnel about any exceptions made to MFA authentication and examining the circumstances;

REQ. 8: IDENTIFY ACCESS

OVERVIEW

8.6 Use of application and system accounts and associated authentication factors is strictly managed

- This sub-requirement is about app/system accounts, which are supposed to not be used by users themselves;
- Interactive use is prohibited unless in exceptional circumstances, and with explicit justification/approval, passwords are not hardcoded and must be regularly changed;

This is usually tested through:

- Examining application and system accounts, app development procedures and/or login records;
- Examining password change records and password change procedures;





REQ. 8: IDENTIFY ACCESS

REQ. 8: IDENTIFY ACCESS **OVERVIEW**

How can we summarize, then, this requirement?

- Users must have unique accounts that can be tied to their actions regarding cardholder data. Accounts must be unique, removed when inactive, periodically checked;
- Authentication must be strong. At least one additional factor, strong passwords changed frequently, lockouts on failed logins, no sharing physical authentication devices;
- MFA for certain situations. Remote admins, users from outside networks, and all CDE access, with at least 2 factors;
- MFA mechanisms must work correctly, with no bypassing, no vulnerabilities, and no access before authentication;
- App/system accounts cannot be used interactively, and must have frequently-changed passwords, not hardcoded;

REQ. 8: IDENTIFY ACCESS

OVERVIEW

EXAMPLES

/01 90-DAY INACTIVITY

There may be legitimate reasons or not for the 90-day inactivity (vacation, parenthood leave). The user management system should be aware of exceptions.

/02 NOT A GOLD STANDARD

One area where the PCI-DSS are not very demanding in compliance, but just “basic” is in password requirements - there is other much stricter regulation.

/03 MFA, NOT 2FA

The reason why MFA is multi-factor and not 2-factor is because some organizations may wish to go over two factors and use more. The PCI-DSS only demand 2.

REQ. 8: IDENTIFY ACCESS

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization creates a unique username for every employee operating the PoS, to track their actions regarding card data;
- Strong password requirements are implemented for all users;
- User accounts are locked after a certain amount of failed logins, especially for employees at the counter;

E-COMMERCE STORE

- The organization establishes MFA for all admin access to the website's backend, and all access of card data through internal interfaces;
- The organization uses a secure protocol (SSH with key-based authentication) for remote access to all systems, and regularly reviews all user accounts to verify privileges;

HOTEL CHAIN

- The organization adopts a centralized solution (Active Directory) to manage user identities and authentication across all locations;
- Strong authentication methods, including smart cards in the real world, are used for all access to systems with CHD data (physically and remotely);

PAYMENT PROCESSOR

- The organization deploys an enterprise identity and access management system for user authentication for all system components and applications;
- The organization uses risk-based authentication, requiring additional factors, based on user behavior and location, for example;

REQ. 8: IDENTIFY ACCESS

OVERVIEW

KEY TAKEAWAYS

/01 8.1 PROCESSES DEFINED

Our usual sub-requirement. All documentation must be accurate and in use, and the same for the definition of roles and responsibilities.

/03 8.3 STRONG AUTH

Action must have one additional authentication factor, passwords must be strong and encrypted and users aware of good practices. Lockouts on failed attempts.

/05 8.5 MFA MECHANISM

MFA must work. At least two different factors, no replay actors, no bypassing MFA, and no access granted until complete MFA authentication achieved.

/02 8.2 USER IDENTIFICATION

User accounts must be unique, no group accounts, sessions expire after 15 minutes, expired accounts are removed, third-party visitors have temporary access.

/04 8.4 MFA SITUATIONS

Administrators that are remote, users outside our networks and all users dealing with card data must authenticate with MFA.

/06 8.6 APP/SYSTEM ACCOUNTS

App/system accounts cannot be used interactively except for exceptional circumstances, passwords must not be hardcoded and must be changed periodically.